信息安全测评与风险评估

4.3 数据库安全配置核查

授课教师：张玉



目录

CONTENTS

01 案例导入：数据库被拖库，日志里却什么都没有

02 关键知识：7 个维度与核查命令

03 动手实验：西普真机取证 + 判定

04 课内小结与下节预告

Part.01

案例导入——
数据库被拖库，日志里却什么都没有



案例导入——“沉默的数据库”

Q:数据库被拖库了，但日志里什么都没有——问题出在哪?

某电商平台数据泄露事后调查：

- 密码策略未配置，DBA弱口令
- 审计日志未启用，无法追溯
- SA账户未禁用，允许远程登录
- 未做网络隔离（0.0.0.0:3306）
- 数据明文存储，备份未加密

先想一想（30 秒）

- 1. 上面 5 个问题，分别对应等保里的哪个测评维度？
- 2. 为什么"日志里什么都没有"比数据泄露本身更严重？
- 3. 换你来查这个库，第一条命令你会敲什么？



数据库是信息系统的“心脏”，数据泄露往往从安全配置的“漏洞”开始。

学习目标

学完这一节，你应该能做到：

1. 说清数据库在等保里的 7 个测评维度各自查什么
2. 在 MySQL 和 SQL Server 上用命令查出账号、口令、权限、审计的真实配置
3. 认出弱口令、空口令、SA 未禁用、无审计、0.0.0.0 监听这些典型隐患
4. 录入实测值、做四档判定，导出规范的测评记录表
5. 针对不合规项，写出可直接执行的 SQL 或配置修改建议

Part.02

关键知识——7 个维度怎么查



数据库安全测评——在等保标准中的位置

GB/T 22239-2019 安全技术要求 → 安全计算环境 → 数据库层

安全计算环境涉及数据库的测评指标（共7个维度）：

维度	测评内容核心关注点	测评方法（检查项）
1.身份鉴别	密码策略、登录失败处理、远程管理安全	登录数据库查看配置
2.访问控制	账户权限、默认账户、最小权限原则	查看用户/权限配置
3.安全审计	审计功能是否启用、审计内容是否完整	查看审计配置与日志
4.入侵防范	最小安装、关闭高危端口/服务	查看服务/端口配置
5.数据完整性	传输/存储过程中的完整性保护	查看加密/校验配置
6.数据保密性	传输/存储过程中的加密保护	查看加密配置
7.数据备份恢复	备份策略、恢复机制	查看备份配置

1.身份鉴别测评——数据库的第一道防线

GB/T 22239 第三级 安全计算环境
→ 身份鉴别

核心检查项（针对数据库）		
序号	检查项与要求	常见不合规示例
1	**身份标识与鉴别：**用户登录需鉴别，标识应唯一	存在空口令账户
2	**密码复杂度：**配置策略（≥8位，含大小写+数字+特殊字符）	未装validate_password插件
3	**密码定期更换：**密码应定期更换（建议90天）	default_password_lifetime=0
4	**登录失败处理：**启用失败处理（限制非法登录次数）	无账户锁定策略
5	**远程管理安全：**远程管理应采取加密措施（SSL/TLS）	未启用SSL加密

MySQL 操作示例

```
-- 检查/安装密码策略插件SHOW PLUGINS LIKE'validate_password';INSTALL
COMPONENT 'file://component_validate_password';
-- 策略级别: MEDIUM, 最小长度: 12 SET GLOBALvalidate_password.policy =
MEDIUM;SET GLOBALvalidate_password.length = 12;
-- 设置密码90天过期SET GLOBALdefault_password_lifetime = 90;
```

SQL Server 操作示例

```
-- 检查审核级别(应为'all')EXECxp_loginconfig 'audit level';
-- 禁用SA账户ALTER LOGINsaDISABLE;
-- 检查空口令账户
SELECTnameFROMsys.sql_loginsWHEREpassword_hashIS NULL;
```

1.身份鉴别测评——常见问题与整改

常见不合规问题	风险描述	整改建议
未安装密码复杂度插件	用户可设置弱口令，易被暴力破解	安装validate_password插件，启用MEDIUM策略
密码永不过期	长期使用同一密码，泄露风险高	设置default_password_lifetime=90
SA账户未禁用	SA拥有最高权限，被攻击后系统完全沦陷	禁用SA账户，创建专用服务账户
存在空口令账户	任何人都可以无密码登录	检查并删除空口令账户
远程管理未加密	密码在网络中明文传输，可被嗅探	启用SSL/TLS加密连接
无登录失败限制	可无限次尝试密码，易被暴力破解	配置登录失败锁定策略

2.访问控制测评——谁有权，访问什么

GB/T 22239 第三级 安全计算环境 → 访问控制

核心检查项（针对数据库）：

检查项	合规要求	不合规示例
账户分配	应对登录的用户分配账户和权限	多个运维人员共用一个账户
默认账户	应重命名或删除默认账户，修改默认口令	SA账户未禁用

MySQL操作示例

MySQL

```
-- 检查root账户是否只允许本地登录
SELECT user, host FROM mysql.user WHERE user='root';

-- 删除匿名用户
DELETE FROM mysql.user WHERE User='';
-- 创建专用应用账户（最小权限）
```

SQL Server操作示例

SQL Server

```
-- 检查SA账户状态
SELECT name, is_disabled FROM sys.server_principals;

-- 禁用SA账户
ALTER LOGIN sa DISABLE;
-- 创建角色并分配最小权限
```